

DOKUMENT 01

PRODUKTVISION, PROBLEM & BUSINESS CASE

Strategischer Bauplan für eine Managed-ISMS-Plattform, die Sicherheitsarbeit in Entscheidungen, Services und messbaren Wert übersetzt.

Arbeitsbezeichnung: ISMS Managed Service Platform

Dokumentstatus: Erstellt - Version 1.0

Stand: 21. Juli 2026

Eigentum/Branding: Eigenständiger, neutraler Produktentwurf

Zweck: Strategischer Rahmen für Produkt, Nutzen, Geschäftsmodell und Erfolg

Dieses Dokument definiert das strategische Warum des Produkts. Funktionsdetails, Fachlogik, Technik und Preisgestaltung werden in den nachgelagerten Konzeptsdokumenten konkretisiert.

1. Dokumentauftrag und Leselogik

Strategische Leitplanke - kein Featurekatalog und keine Marktprognose

Dokument 01 beschreibt, welches Problem die Plattform löst, welches Zielbild sie verfolgt, für wen sie Wert erzeugt und warum daraus ein tragfähiges Managed-Service-Geschäft entstehen kann. Es übersetzt das freie Brainstorming in eine verbindliche strategische Grundlage für alle späteren Produkt-, Fach-, UX-, Technik- und Umsetzungsdokumente.

ENTSCHEIDUNG

Die Plattform wird als eigenständiges B2B2B-Produkt konzipiert: Ein Beratungs- oder Managed-Service-Anbieter betreibt die Plattform und erbringt darüber wiederkehrende ISMS-Leistungen für seine Kunden. Eine direkte Unternehmenslizenz bleibt als spätere Option offen.

1.1 Was dieses Dokument verbindlich festlegt

- die zentrale Produktdefinition und das Nutzenversprechen;
- das zu lösende Problem aus Kunden-, Berater-, Management- und Betreiberperspektive;
- die wirtschaftliche Wertlogik und die Business-Case-Hypothesen;
- strategische Differenzierung, Produktprinzipien und Nicht-Ziele;
- Erfolgskriterien, Risiken, Annahmen und offene Entscheidungen.

1.2 Was bewusst später definiert wird

Wettbewerb und Marktdaten stehen in Dokument 02; Rollen in Dokument 03; Funktionen in Dokument 05; Servicepakete und Preise in den Dokumenten 13 bis 15; Technik, Sicherheit und KI in den Dokumenten 17 bis 20C.

Leseregel: Aussagen sind als ENTSCHEIDUNG, ANNAHME, OFFENE FRAGE oder SPÄTERE IDEE gekennzeichnet. Marktzahlen und Preise werden nicht erfunden.

2. Executive Summary

Die Plattform in einer Seite

Die ISMS Managed Service Platform ist ein rollenbasiertes Betriebs-, Entscheidungs- und Service-System für Informationssicherheit. Sie verbindet ein lebendes Unternehmensmodell mit ISMS-Fachlogik, Risiken, Maßnahmen, Nachweisen, Reporting, Beratung und Managed Services. Ihr Zweck ist nicht, mehr Daten anzuzeigen, sondern aus verteilten Daten die nächste sinnvolle Entscheidung und deren erwartete Wirkung abzuleiten.

Problem

ISMS-Arbeit ist dokumenten-, tabellen- und terminlastig. Zusammenhänge, Prioritäten und wirtschaftliche Wirkung bleiben schwer erkennbar.

Produktantwort

Ein digitaler Unternehmenszwilling verbindet Prozesse, Assets, Risiken, Controls, Maßnahmen, Nachweise, Audits, Services und Verantwortliche.

Kundennutzen

Kunden erkennen Ziel, Zustand, wirksamsten nächsten Schritt und Wirkung von Investitionen oder Services.

Betreibernutzen

Serviceanbieter standardisieren Arbeit, reduzieren Routineaufwand und betreuen mehr Mandanten mit konsistenter Qualität.

Softwarelizenz, wiederkehrende Managed Services und modulare Erweiterungen bilden eine gemeinsame Umsatzlogik. Die Differenzierung entsteht aus Decision-first UX, Zielnavigator, Digital Twin, Service-Native Design und nachvollziehbarer Wirkungslogik.

NORTH STAR

Jeder Nutzer versteht jederzeit, was sich verändert hat, was jetzt zählt und welcher nächste Schritt im Verhältnis zu Ziel, Risiko, Zeit, Budget und Verantwortung die größte Wirkung erzeugt.

3. Produktvision und strategisches Zielbild

3.1 Vision

VISION

Informationssicherheit wird nicht länger als periodisches Dokumentationsprojekt betrieben, sondern als kontinuierlich navigierbares, messbares und gemeinsam erbrachtes Managementsystem. Die Plattform wird zum Betriebssystem für Sicherheitsarbeit und zum skalierbaren Delivery-System für Managed ISMS.

ISO/IEC 27001 beschreibt ein ISMS als System, das aufgebaut, umgesetzt, aufrechterhalten und fortlaufend verbessert wird. Die Produktvision nimmt diese kontinuierliche Managementlogik ernst: Der Zustand des Unternehmens, seine Ziele, Risiken, Maßnahmen und Nachweise werden nicht nur zu Auditzeit gepflegt, sondern laufend miteinander verbunden und steuerbar gemacht. ^[51]

3.2 Die fünf strategischen Fragen

Nr.	Leitfrage	Produktantwort
1	Wo stehen wir?	Aktueller Zustand, Reifegrad, Risikolage, Datenqualität und Trend.
2	Wo wollen wir hin?	Kundenspezifisches Zielprofil statt generischem Idealzustand.
3	Warum ist der Zustand so?	Ursachen, Abhängigkeiten, fehlende Controls und Datenlücken.
4	Was ist der beste nächste Schritt?	Priorisierung nach Wirkung, Machbarkeit, Zeit, Budget und Verantwortung.
5	Was bewirkt die Entscheidung?	Simulation von Risiko-, Ziel-, Aufwands- und Servicewirkung.

3.3 Zielbild für 2030 - ohne technische Vorfestlegung

- Ein Kunde besitzt einen digitalen, historisierten Zwilling seines Informationssicherheitszustands.
- Ein Berater steuert ein Portfolio nicht über E-Mails und Tabellen, sondern über verdichtete Missionen, Abweichungen und Entscheidungspunkte.
- Ein Executive sieht Geschäftsrisiken, Zielerreichung, Investitionsoptionen und Entscheidungsbedarf in verständlicher Sprache.
- Managed Services sind als klare, messbare Leistungen mit Verantwortlichkeiten, Rhythmus und Wirkung im Produkt verankert.
- Die Plattform lernt aus standardisierten Arbeitsweisen und anonymisierbaren Mustern, ohne Kundendaten unzulässig zu vermischen.
- KI unterstützt Erklärung, Entwurf und Analyse; die Kernprozesse bleiben nachvollziehbar und auch ohne generative KI funktionsfähig.

ENTSCHEIDUNG

Der Prototyp stellt dieses vollständige Zielbild als glaubwürdiges Produkt dar. Mehrere Unternehmen, Rollen und End-to-End-Szenarien werden mit realistischen synthetischen Daten simuliert; die Bauphasen werden erst in Dokument 20C priorisiert.

4. Problemdefinition

Nicht ein einzelner Prozess ist kaputt - die gesamte Informations- und Servicekette ist fragmentiert

4.1 Kundenproblem

Organisationen müssen Informationssicherheitsrisiken dauerhaft managen, Anforderungen erfüllen, Maßnahmen umsetzen und Managemententscheidungen vorbereiten. Standards und Regulierungen verlangen dabei einen risikobasierten, organisatorischen und dokumentierten Ansatz: NIS2 fordert geeignete und verhältnismäßige technische, operative und organisatorische Risikomanagementmaßnahmen; DORA verlangt für Finanzunternehmen einen soliden, umfassenden und gut dokumentierten IKT-Risikomanagementrahmen. ^{[S3] [S4]}

- Daten liegen in Dokumenten, Tabellen, Ticketing, CMDB, Scannern, SIEM, E-Mail und Köpfen einzelner Personen.
- Risiken, Controls, Nachweise und Geschäftsprozesse sind nur unvollständig miteinander verknüpft.
- Managementberichte entstehen manuell und zeigen häufig Status statt Ursache, Wirkung und Entscheidungsoptionen.
- Kunden werden an generischen Framework-Zielen gemessen, obwohl Risikoappetit, Budget, Branche und Zielniveau unterschiedlich sind.
- Auditvorbereitung erzeugt periodische Hektik, weil das ISMS zwischen Prüfungen nicht konsistent betrieben wird.
- Wissen und Kontinuität hängen stark von einzelnen ISMS-Verantwortlichen oder externen Beratern ab.

4.2 Berater- und Serviceproblem

- Wiederkehrende Tätigkeiten werden je Mandant erneut vorbereitet, recherchiert, dokumentiert und formatiert.
- Portfolio-Priorisierung geschieht über Erfahrung, Kalender, E-Mail und manuelle Statusabfragen statt über aktuelle Wirkungssignale.
- Beraterzeit fließt in Reports, Nachverfolgung, Konsolidierung und Präsentationen statt in hochwertige Beratung.
- Kapazität, Vor-Ort-Termine, Reisezeit, Auditfenster und Skills werden selten mit Risiko- und Kundenprioritäten zusammengeführt.
- Standardisierung ist schwierig: Gute Methoden bleiben in persönlichen Vorlagen oder einzelnen Teams, statt als wiederverwendbare Workflows zu skalieren.
- Service-Opportunities werden unsystematisch erkannt und der Nutzen bestehender Services ist gegenüber Kunden nicht ausreichend sichtbar.

4.3 Managementproblem

- Executives erhalten zu viele technische Details und zu wenig konkrete Entscheidungsoptionen.
- Budgets lassen sich schwer mit Risiko-, Resilienz- oder Zielwirkung verbinden.
- Fortschritt wird über Erledigungsquoten berichtet, obwohl erledigte Maßnahmen nicht automatisch wirksam sind.
- Unsicherheit und Datenlücken werden selten sichtbar gemacht, wodurch scheinpräzise Kennzahlen entstehen.

5. Ursachen, Folgen und Dringlichkeit

5.1 Problembaum

Ursache	Unmittelbare Folge	Geschäftliche Konsequenz
Fragmentierte Werkzeuge und Dateien	Mehrfache Datenerfassung, widersprüchliche Stände	Hoher Koordinationsaufwand und geringe Verlässlichkeit
Kontroll- und dokumentzentrierte UX	Listen statt Entscheidungslogik	Management kann Prioritäten und Investitionen schwer bewerten
Projektlogik statt Regelbetrieb	Aktivität konzentriert sich auf Audits und Stichtage	Schwankende Reife und wiederkehrende Audit-Hektik
Geringe Standardisierung im Servicebetrieb	Jeder Mandant wird weitgehend individuell bearbeitet	Skalierung erfordert proportional mehr Personal
Fehlende Kausalität und Wirkungsmodelle	Risikoscores bleiben schwer erklärbar	Geringes Vertrauen in Empfehlungen und KPIs
Manuelle Reporting- und Evidenzarbeit	Berater produzieren Folien und suchen Nachweise	Weniger Zeit für Analyse, Beratung und Kundenkontakt

5.2 Warum jetzt?

Die Dringlichkeit entsteht aus drei gleichzeitig wirkenden Entwicklungen: einer dynamischen Bedrohungslage, steigenden Governance- und Nachweisanforderungen sowie einem begrenzten Angebot an qualifizierten Fachkräften. ENISA analysierte für den Threat Landscape 2025 insgesamt 4.875 Vorfälle und beschreibt ein weiterhin dynamisches europäisches Bedrohungsumfeld. Der ENISA-Bericht zu NIS-Investitionen 2025 verweist zugleich auf Umsetzungsherausforderungen, Fachkräftemangel und eine stärkere technologische Unterstützung der Cybersecurity-Arbeit. ^{[SS] [SG]}

Für die Produktstrategie folgt daraus keine Garantie für Markterfolg, wohl aber eine belastbare Problemrichtung: Sicherheitsarbeit muss kontinuierlicher, nachvollziehbarer und effizienter werden. Eine Plattform, die nur weitere Dokumentation erzeugt, verschärft das Problem. Eine Plattform, die Informationen verdichtet und Servicearbeit standardisiert, adressiert es.

Strategische Konsequenz

Das Produkt wird nicht um eine Norm oder ein Audit herum gebaut. Es wird um kontinuierliche Entscheidungen, individuelle Zielzustände und wiederholbare Servicezyklen herum gebaut. Standards und Regulierungen werden als erweiterbare Anforderungen und Mappings integriert.

5.3 Problem, das ausdrücklich nicht gelöst wird

Die Plattform verhindert keine Cyberangriffe und ersetzt keine technischen Sicherheitskontrollen. Sie verbessert die Fähigkeit, relevante Informationen zu verbinden, Risiken zu verstehen, Maßnahmen zu priorisieren, Verantwortungen zu steuern, Nachweise zu führen und externe Unterstützung wirksam einzusetzen.

6. Produktantwort und Nutzenversprechen

6.1 Zentrale Produktdefinition

PRODUKTDEFINITION
Eine mandantenfähige Enterprise-Plattform, die den Informationssicherheitszustand eines Unternehmens als digitalen Zwilling modelliert, ISMS-Prozesse und Managed Services orchestriert und rollenbezogen in nachvollziehbare Entscheidungen, Aufgaben, Nachweise, Reports und Wirkungssimulationen übersetzt.

6.2 Drei Produkte in einem

Erlebniswelt	Primäre Frage	Kernnutzen
Executive / Management	Wo müssen wir entscheiden und investieren?	Geschäftsrisiken, Zielerreichung, Wirkung, Budgetoptionen und Managementkommunikation
Kunde / ISMS-Team	Was müssen wir heute tun und warum?	Geführter Betrieb, Prioritäten, Zusammenarbeit, Nachweise und Zielnavigation
Beratung / Operations	Welche Mandanten brauchen Aufmerksamkeit und wie skalieren wir Qualität?	Portfolio-Steuerung, Workflows, Kapazität, Servicebetrieb, Reports und Opportunities

6.3 Die sechs Nutzenversprechen

Orientierung Ein konsistenter Zielnavigator ersetzt unverbundene Statuslisten.	Priorisierung Die Plattform ordnet Arbeit nach Wirkung und Rahmenbedingungen, nicht nur nach Fälligkeit.
Nachvollziehbarkeit Jede Empfehlung erklärt Ursache, Datenbasis, Unsicherheit und erwartete Wirkung.	Produktivität Wiederkehrende Prozesse, Reports, Evidenzanforderungen und Workflows werden standardisiert und automatisiert.
Skalierbarkeit Berater steuern Portfolios und wiederverwenden Methoden über Mandanten hinweg.	Wertnachweis Kunden und Betreiber sehen Fortschritt, Servicewirkung, Zeitersparnis und Entscheidungsqualität.

DESIGNGESETZ

Jede Hauptseite beantwortet eine konkrete Frage: Was ist das? Warum ist es wichtig? Womit hängt es zusammen? Wie entwickelt es sich? Was ist der beste nächste Schritt?

7. Produkt- und Service-Betriebsmodell

Die Plattform ist bewusst kein reines SaaS-Tool. Ihr strategischer Vorteil entsteht aus dem Zusammenspiel dreier Ebenen. Die Software erzeugt Struktur und Transparenz; standardisierte Managed Services erzeugen wiederkehrende Ergebnisse; die Lern- und Automatisierungsschicht verbessert beide Ebenen fortlaufend.

Ebene	Inhalt	Wirtschaftliche Funktion
1. Plattform	Digital Twin, ISMS-Kern, Decision Center, Reporting, Zusammenarbeit, Integrationen	Lizenz-/Plattformumsatz, geringere Delivery-Kosten, Datenbasis
2. Managed Services	Wiederkehrende fachliche Leistungen mit Scope, Rhythmus, Verantwortungen und Ergebnissen	Wiederkehrender Serviceumsatz, Kundenbindung, messbarer Mehrwert
3. Intelligence & Automation	Standardisierte Workflows, Regeln, Benchmarks, KI-Unterstützung und Wirkungsanalyse	Produktivitätsgewinn, Differenzierung, Qualitätssteigerung und Skaleneffekte

7.1 Kundenspezifisches Zielprofil statt Einheitsmodell

- angestrebter Reifegrad oder regulatorischer Mindestzustand;
- Zertifizierungs- oder Auditziele als optionale, konkrete Ziele;
- Risikobereitschaft und priorisierte Geschäftsprozesse;
- Budget- und Zeitrahmen;
- interne Fähigkeiten und verfügbare Kapazität;
- gewünschter Automatisierungs- und Managed-Service-Anteil.

Aus diesen Parametern entsteht die Strategie-DNA des Kunden. Sie steuert Empfehlungen, Routen, Missionen, KPIs und Servicevorschläge. Damit wird ein Unternehmen nicht für einen niedrigeren Zielgrad „bestraft“, wenn dieser bewusst, begründet und risikoadäquat gewählt wurde.

7.2 Service-Native statt nachträglicher Upsell

Service-Opportunities werden nicht als Werbebanner präsentiert. Sie entstehen aus einer fachlichen Lücke: fehlende Kapazität, wiederkehrende Überfälligkeit, geringe Control-Wirksamkeit, bevorstehender Termin oder hoher manueller Aufwand. Die Plattform muss immer erklären, warum ein Service empfohlen wird, welches Ergebnis er liefert und welche Alternative der Kunde intern umsetzen kann.

ENTSCHEIDUNG

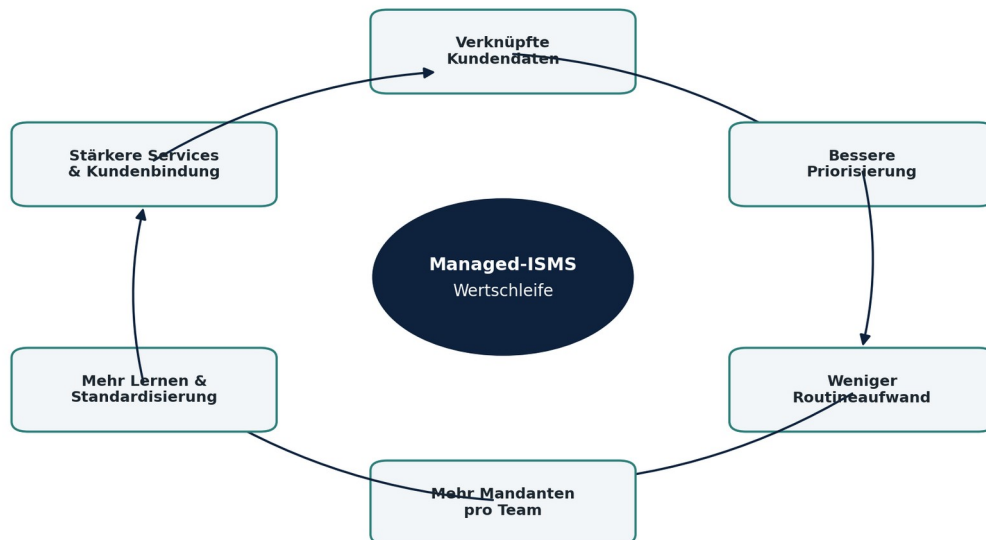
Software und Managed Services nutzen dasselbe Daten-, Aufgaben-, Nachweis- und Wirkungsmodell. Ein Service ist daher kein externer Vertrag ohne Produktbezug, sondern ein steuerbarer Betriebsbaustein innerhalb der Plattform.

8. Business Case: Wertschleife und wirtschaftliche Logik

8.1 Kernthese

BUSINESS-CASE-These

Wiederkehrender Umsatz wird profitabel, wenn die Plattform den manuellen Delivery-Aufwand je Mandant senkt, die Qualität standardisiert, Serviceerweiterungen datenbasiert unterstützt und den wahrgenommenen Kundennutzen fortlaufend sichtbar macht.



Ziel: Software, Servicebetrieb und Lernen verstärken sich gegenseitig.

Abbildung 1: Managed-ISMS-Wertschleife (Produktidee, keine empirische Marktbehauptung)

8.2 Werthebel für den Plattformbetreiber

- Mehr wiederkehrender Umsatz: modulare Services ersetzen oder ergänzen einmalige Projekte.
- Höherer Beraterhebel: ein Team kann mehr Mandanten betreuen, ohne Qualität proportional zu Personal zu skalieren.
- Höherwertige Arbeit: weniger Zeit für Konsolidierung und Folien, mehr Zeit für Analyse, Entscheidungen und Kundenbeziehung.
- Bessere Bindung: Zielhistorie, Nachweise, Services und Workflows bilden einen kontinuierlichen Betriebszusammenhang.
- Gezieltere Expansion: Servicebedarf wird aus realen Daten und wiederkehrenden Mustern erkennbar.
- Konsistentere Delivery: wiederverwendbare Workflows, Definitionen, Qualitätsprüfungen und Reports reduzieren Streuung.

8.3 Werthebel für den Kunden

- schnellere Orientierung und weniger Koordinationsaufwand;
- bessere Priorisierung knapper Budgets und interner Kapazitäten;
- kontinuierliche Betriebsfähigkeit statt Auditprojekt;
- geringere Abhängigkeit von einzelnen Wissensträgern;
- zielgruppengerechte Kommunikation für CISO, Management und Auditoren;
- nachvollziehbare Entscheidung zwischen interner Umsetzung und Managed Service.

9. Wirtschaftliches Messmodell

Formeln vor Fantasiezahlen

Dokument 01 definiert die Mechanik des Business Case, aber keine konkreten Marktpreise, Margen oder Umsatzprognosen. Diese werden nach Marktanalyse und Servicekalkulation in Dokument 14 ergänzt. Bis dahin wird mit transparenten Kennzahlen, Indizes und validierbaren Hypothesen gearbeitet.

9.1 Kernformeln

Kennzahl	Definition	Zweck
Annual Recurring Revenue	aktive Kunden x durchschnittlicher monatlicher Plattform- und Serviceumsatz x 12	Wiederkehrende Umsatzbasis
Deckungsbeitrag	wiederkehrender Umsatz minus direkte Delivery-, Plattform- und Drittanbieter-Kosten	Wirtschaftlicher Beitrag des Betriebsmodells
Beraterhebel	aktive betreute Mandanten oder Serviceumsatz je Delivery-FTE	Skalierung ohne proportionale Personalzunahme
Automatisierungsrendite	vermiedene manuelle Stunden im Verhältnis zu automatisierbaren Stunden	Messung realer Arbeitseinsparung
Service Attach Rate	Kunden mit mindestens einem Managed Service im Verhältnis zu Plattformkunden	Verbindung von Software und Service
Expansion Rate	Kunden mit sinnvoller Serviceerweiterung im Verhältnis zu dafür geeigneten Kunden	Qualität statt aggressivem Upselling
Time-to-Value	Zeit vom Onboarding bis zum ersten sichtbar realisierten Nutzen	Frühe Kundenerfahrung
Value Realization	realisierte Ziel-, Risiko-, Zeit- und Qualitätsverbesserungen gegenüber dem vereinbarten Ausgangspunkt	Nachweis des Kundenwerts

9.2 Illustratives Effizienzmodell

ANNAHME - zu validieren

Indexierter Beispielwert, keine Prognose: Wird der heutige wiederkehrende administrative Aufwand mit 100 Einheiten angesetzt, könnte die Zielarchitektur durch Standardisierung, automatische Datensammlung, Workflow-Automation und Reportgenerierung einen deutlich niedrigeren Wert anstreben. Zielkorridor und Einsparanteile müssen durch Interviews, Time Studies und Pilotmandate validiert werden.

Effekttreiber	Beispielhafte Wirkung auf Aufwandindex	Validierung
Standardisierte Workflows	-10 bis -20	Zeitmessung je Servicezyklus
Automatische Datensynchronisation	-10 bis -25	Vergleich manueller vs. integrierter Datenpflege
Report- und Präsentations-Engine	-10 bis -20	Erstellzeit vor/nach Plattform
Portfolio-Priorisierung	-5 bis -15	Zeit für Statusklärung und Koordination
Neue Plattform- und Qualitätsaufgaben	+10 bis +20	Betriebs- und Reviewaufwand
Möglicher Zielkorridor	50 bis 75 statt 100	Pilotmessung, keine zugesagte Einsparung

9.3 Grenzen der Monetarisierung

- Risikoreduktion wird nicht automatisch monetarisiert. Serviceempfehlungen benötigen fachliche Begründung; Effizienz und Benchmarking dürfen Qualität, Freigaben, Datenschutz und Kundenvertrauen nicht schwächen.

10. Strategische Differenzierung und Verteidigbarkeit

Die Differenzierung entsteht nicht durch ein einzelnes Feature. Sie entsteht aus einer schwer kopierbaren Kombination aus Datenmodell, Nutzerlogik, Servicebetrieb und wiederverwendbarem Fachwissen. Die endgültige Wettbewerbsbewertung erfolgt in Dokument 02.

Differenzierungsbaustein	Warum er relevant ist	Potenzielle Verteidigbarkeit
Digitaler Unternehmenszwilling	Verknüpft Ursache, Wirkung, Historie und Verantwortung statt isolierter Register	Wächst mit Datenqualität, Beziehungen und Nutzungshistorie
Decision-first UX	Führt Rollen zu Entscheidungen statt durch Menüs und Tabellen	Konsistente Produktlogik über alle Module
Individueller Zielnavigator	Optimiert gegen kundenspezifische Ziele, Budget und Risikoappetit	Tief in Datenmodell, Simulation und Serviceplanung eingebettet
Managed-Service-Native Architektur	Services, Aufgaben, Nachweise und Wertmessung sind Produktobjekte	Betriebswissen und wiederverwendbare Delivery-Workflows
Wirkungs- und Kausalitätslogik	Erklärt, warum etwas wichtig ist und was eine Entscheidung verändert	Methodik, historische Ergebnisse und validierte Modelle
Reporting & Communication Engine	Erzeugt rollen- und zielgruppengerechte PDF-/PPTX-Ergebnisse	Vorlagen, Datenlogik und wiederverwendbare Storylines
Portfolio- und Ressourcenintelligenz	Verbindet Mandantenrisiko, Fristen, Skills, Reisezeit und Kapazität	Servicebetriebsdaten und operative Lernkurve
Vertrauens- und Datenqualitätsmodell	Macht Unsicherheit, Quellen und Datenlücken sichtbar	Governance, Auditierbarkeit und Nutzervertrauen

10.1 Strategische Positionierung

POSITIONIERUNG
Für Beratungs- und Managed-Service-Anbieter, die Informationssicherheit über viele Kunden kontinuierlich betreiben müssen, verbindet die Plattform ISMS, Kundensteuerung, Service Delivery und Managemententscheidungen in einem System. Anders als dokumentenzentrierte GRC-Tools oder reine Compliance-Tracker ist sie um einen digitalen Zwilling, individuelle Zielrouten und den wirtschaftlich messbaren Managed-Service-Betrieb gebaut.

10.2 Was nicht als Burggraben ausreicht

- ein generischer KI-Chatbot;
- ein weiteres Reifegrad-Dashboard;
- eine große Kontrollbibliothek ohne Nutzungslogik;
- automatisch erzeugte Reports ohne belastbare Datenbasis;
- Branding oder einzelne Vorlagen;
- eine reine Sammlung von Integrationen.

11. Erfolgssystem und KPI-Baum

11.1 North-Star-Metrik

ANNAHME

Geeignete North-Star-Metrik: Anteil der priorisierten Entscheidungen und Maßnahmen, deren erwartete Wirkung innerhalb des vereinbarten Zeitraums realisiert und nachvollziehbar bestätigt wurde. Diese Metrik verbindet Nutzung, Umsetzung, Datenqualität und Ergebnis.

11.2 Strategische Erfolgsdimensionen

Dimension	Beispielkennzahlen	Warnsignal
Kundenergebnis	Zielerreichung, Control-Wirksamkeit, reduzierte kritische Lücken, Time-to-Value	Viele erledigte Tasks ohne messbare Wirkung
Nutzerorientierung	Zeit bis zur Entscheidung, Nutzung der Missionen, verständliche Reports, geringe Abbruchrate	Nutzer exportieren Daten und arbeiten außerhalb weiter
Delivery-Effizienz	Aufwand je Servicezyklus, Mandanten/FTE, Automatisierungsrendite, Reportzeit	Mehr Mandanten führen sofort zu proportional mehr Aufwand
Geschäftsmodell	ARR, Attach Rate, Expansion, Retention, Deckungsbeitrag	Umsatz entsteht nur aus Einführungsprojekten
Qualität & Vertrauen	Datenvollständigkeit, Empfehlungskonfidenz, Reviewquote, Fehler- und Rücknahmerate	Scheinpräzision, ungeklärte Quellen oder unkontrollierte KI-Ausgaben
Plattformgesundheit	Integrationsstabilität, Laufzeit, Supportfälle, Wiederanlauf	Manuelle Nacharbeit kompensiert technische Schwächen

11.3 Erfolg des Prototyps

- Ein Entscheider versteht Produkt, Nutzen und Geschäftsmodell innerhalb der ersten zwei Minuten.
- Mehrere Rollen sehen glaubwürdig unterschiedliche Perspektiven auf dieselben Kundendaten.
- Mindestens eine End-to-End-Geschichte verbindet Bedrohung oder Veränderung mit Risiko, Maßnahme, Service, Wirkung und Report.
- Das Produkt wirkt vollständig, nicht leer: mehrere Unternehmen, realistische Historien, Aufgaben, Nachweise und Reports sind vorhanden.
- Der Prototyp demonstriert Skalierung: Portfolio-Übersicht, wiederverwendbare Workflows und automatische Deliverables.
- KI-Funktionen sind klar von deterministischer Logik getrennt und besitzen sichtbare Fallbacks.

Qualitätsregel

Ein Wow-Moment ist nur dann strategisch relevant, wenn er ein reales Problem löst, messbaren Nutzen erzeugt und in die gemeinsame Produktlogik passt.

12. Strategischer Umfang, Nicht-Ziele und Risiken

12.1 Im Produktkern

- rollenbezogene Decision Center für Executive, Kunde/ISMS und Beratung/Operations;
- digitaler Unternehmenszwillings mit historisierten Beziehungen;
- ISMS-Kernprozesse, Zielprofile, Reifegrad, Risiken, Controls, Maßnahmen und Nachweise;
- Managed-Service-Betrieb, Servicekatalog, Portfolio- und Ressourcensteuerung;
- Reporting-, PDF- und PowerPoint-Engine;
- Integrationen, Automatisierung, Workflows und nachvollziehbare KI-Unterstützung;
- strikte Mandantentrennung, Rollen, Auditierbarkeit und Datenqualitätsmodell.

12.2 Klare Nicht-Ziele

- kein Ersatz für SIEM, EDR, Schwachstellenscanner, Ticketing, CMDB, ERP oder Kalender;
- kein ausschließliches Audit-Readiness- oder Zertifizierungsprodukt;
- kein PwC-proprietäres System und keine Nutzung nichtöffentlicher PwC-Daten, Preise oder Vorlagen;
- keine vollautonome KI für Risikoakzeptanz, Managementfreigaben oder sicherheitskritische Entscheidungen;
- kein Versprechen, Cybervorfälle zu verhindern oder finanzielle Schäden exakt vorherzusagen;
- kein Marktplatz voller Funktionen ohne gemeinsame Daten- und Entscheidungssystematik.

12.3 Strategische Risiken und Gegenmaßnahmen

Risiko	Auswirkung	Gegenmaßnahme im Konzept
Überbreite Produktvision	Komplexität und langsame Umsetzung	Modulare Architektur, klare Abhängigkeiten und phasenweiser Bauplan
Scheinpräzise Scores	Vertrauensverlust und Fehlentscheidungen	Datenqualität, Konfidenz, Quellen und nachvollziehbare Modelle
Zu starke KI-Abhängigkeit	Unzuverlässige Kernprozesse und Kostenrisiken	KI-gestützt statt KI-abhängig; deterministische Fallbacks
Ungeeignete Serviceempfehlungen	Verkaufsdruck und Kundenmisstrauen	fachliche Begründung, interne Alternative und menschliche Freigabe
Unvalidierte Beraterprozesse	Produkt passt nicht zum Alltag	Interviews, Beobachtung, Pilotmandate und Zeitmessungen
Datenschutz bei Cross-Client-Lernen	Rechtliche und Reputationsrisiken	strikte Trennung, Anonymisierung, Einwilligung und Opt-out
Feature-Überladung	Schlechte Anfängererfahrung	rollenbezogene Sichten und progressive Offenlegung

13. Entscheidungen, Annahmen und offene Fragen

13.1 Verbindliche Entscheidungen

ID	Entscheidung
01-D01	Eigenständiger neutraler Produktentwurf; spätere Übernahme oder Branding durch Beratungen möglich.
01-D02	Primäre Geschäftslogik ist service-provider-led B2B2B mit wiederkehrenden Managed Services.
01-D03	Die Plattform wird als vollständiges Zielprodukt konzipiert; Umsetzung wird später phasenweise priorisiert.
01-D04	Digitaler Zwilling, individuelle Zielnavigation und Decision-first UX bilden den strategischen Kern.
01-D05	Audit Readiness ist eine Zieloption, nicht der allgemeine Produktzweck.
01-D06	Executives, Kunden-/ISMS-Teams und Berater erhalten eigene Erlebniswelten auf demselben Datenmodell.
01-D07	Serviceempfehlungen benötigen fachliche Begründung, Wirkung, Transparenz und interne Alternative.
01-D08	PDF- und PowerPoint-Erzeugung gehört zum Kernprodukt und nicht nur in eine spätere Erweiterung.
01-D09	KI unterstützt; kritische Entscheidungen bleiben nachvollziehbar und menschlich freigegeben.
01-D10	Business-Case-Zahlen und Preise werden erst nach Markt- und Servicekalkulation verbindlich.

13.2 Begründete Annahmen

ID	Annahme
01-A01	Beratungs- und Serviceanbieter sind der sinnvollste erste Plattformbetreiber, weil Software- und Servicewert direkt verbunden werden können.
01-A02	Der größte wirtschaftliche Hebel liegt in standardisierbarer wiederkehrender Arbeit, nicht in der vollständigen Automatisierung von Fachentscheidungen.
01-A03	Kunden akzeptieren Serviceempfehlungen eher, wenn Nutzen, Ursache, Alternativen und erwartete Wirkung transparent sind.
01-A04	Ein Graph-orientiertes Unternehmensmodell verbessert Kausalität und Navigation gegenüber isolierten Registern.
01-A05	Synthetische Demodaten reichen aus, um die Produktvision überzeugend darzustellen, solange die Logik konsistent ist.
01-A06	Wirtschaftliche Wirkung kann zunächst über Aufwand, Zielerreichung und Servicequalität glaubwürdiger gezeigt werden als über monetarisierte Schadensvermeidung.

14. Offene Fragen und Ideenparkplatz

14.1 Offene strategische Fragen

ID	Frage	Klärzeitpunkt
01-O01	Wie lautet der Produktname und welche Markenpositionierung wird gewählt?	Vor Pitch / Branding
01-O02	Wird der erste reale Käufer eine Beratung, ein MSSP oder ein Unternehmen mit interner ISMS-Funktion?	Vor Go-to-Market
01-O03	Welche Unternehmensgröße und Branche eignen sich für den ersten Pilot?	Vor Pilotdesign
01-O04	Welche konkreten Berateraufwände sind am größten und am sichersten standardisierbar?	Dokumente 03, 13, 15
01-O05	Welche Kennzahl wird nach Pilotvalidierung zur North-Star-Metrik?	Vor Produktsteuerung
01-O06	Welche Wirkungsmodelle für Risiko, Reifegrad und ROI sind methodisch belastbar?	Dokumente 09 und 10
01-O07	Welche Preis- und Margenlogik ist marktgerecht?	Dokument 14
01-O08	Welche rechtlichen/IP-Bedingungen gelten bei einer späteren Übergabe an PwC oder andere Unternehmen?	Vor externer Übergabe
01-O09	Wie weit darf Cross-Client-Lernen gehen?	Dokument 19
01-O10	Welche Module müssen im ersten Build echt rechnen und welche dürfen mit klar gekennzeichnete Demologik arbeiten?	Dokument 20C

14.2 Ideen für später

- Branchenpakete mit spezifischen Zielfprofilen, Bedrohungslagen, Controls und Managementreports.
- Anonymisiertes Cross-Client-Benchmarking mit Wirksamkeitsmustern und Peer-Gruppen.
- Partner- und Erweiterungsmarktplatz für Workflows, Connectoren, Templates und Services.
- Mobile Companion App für Vor-Ort-Audits, Evidenzaufnahme und Managementfreigaben.
- Boardroom-Simulationen mit mehreren Budget-, Risiko- und Serviceoptionen.
- Lernzentrum für neue ISMS-Verantwortliche mit kontextbezogenen Erklärungen.
- Interne Plattformreife und Qualitätsscore für den Managed-Service-Betrieb.
- Kontrollierte Agenten-Workflows für risikoarme Routineaktivitäten.

Kreativitätsregel

Spätere Ideen bleiben erhalten, dürfen aber das erste umsetzbare System nicht blockieren. Neue Ideen werden nur dann in den Kern aufgenommen, wenn sie Problem, Nutzen und Integration in die bestehende Produktlogik klar erklären.

15. Quellenbasis, Änderungsprotokoll und nächste Schritte

15.1 Externe Quellenbasis

ID	Quelle	Herausgeber / Link
S1	ISO/IEC 27001:2022 - Information security management systems - Requirements	ISO - öffnen
S2	BSI IT-Grundschutz Online-Kurs - Anforderungen anpassen: Wirksamkeit, Eignung, Praktikabilität und Wirtschaftlichkeit	BSI - öffnen
S3	Richtlinie (EU) 2022/2555 (NIS2), insbesondere Artikel 20 und 21	EUR-Lex - öffnen
S4	Verordnung (EU) 2022/2554 (DORA), insbesondere Artikel 6	EUR-Lex - öffnen
S5	ENISA Threat Landscape 2025	ENISA - öffnen
S6	NIS Investments 2025	ENISA - öffnen
S7	BSI IT-Grundschutz Online-Kurs - Grundschutz-Check: kontinuierliche Prüfung und aktuelle Kompendiumsversion	BSI - öffnen

Quellen dienen der strategischen Problembegründung. Sie ersetzen weder eine Rechtsberatung noch die vollständige Auslegung der Standards und Rechtsakte. Fachliche Anforderungen und Mappings werden in den Dokumenten 08, 09 und 19 detailliert.

15.2 Änderungsprotokoll

Version	Datum	Status	Änderung
1.0	21.07.2026	Erstellt	Erstfassung aus Brainstorming, Projektverfassung und aktueller offizieller Quellenbasis.

15.3 Auswirkungen auf Dokument 00

- Status von Dokument 01 wird von „Geplant“ auf „Erstellt“ gesetzt.
- Die Entscheidungen 01-D01 bis 01-D10 werden als dokumentenspezifische Entscheidungen referenziert.
- Offene Fragen 01-O01 bis 01-O10 werden in das zentrale Fragenregister synchronisiert.
- Dokument 03 ist der nächste empfohlene Konzeptschritt; Dokument 02 bleibt bewusst bis nach der vollständigen Produktdefinition offen.

NÄCHSTER SCHRITT

Dokument 03 - Zielgruppen, Rollen und reale Arbeitssituationen erstellen. Dort werden Buyer, Betreiber, Berater, CISO, ISMS-Manager, Executives, Auditoren und Administratoren mit ihren Jobs-to-be-done und realen Nutzungssituationen konkretisiert.